

Auditar la evidencia B

Cincuenta minutos en clase; los minutos de cada ejercicio son un ritmo sugerido y el docente gestiona el tiempo, así que lo que no se cierre en el aula continúa como trabajo independiente. Trabajan sobre la muestra de la tabla de usuarios del caso. Está anonimizada: los usuarios no existen y las contraseñas del ejemplo son las genéricas de manual, pero **los resúmenes se comportan como los de la base de Coopaburrá**.

Antes de empezar. No se evalúa que reproduzcan un resumen. Se evalúa que expliquen **qué propiedad del esquema lo hace débil**, y que documenten la discrepancia entre lo que la documentación afirma y lo que los datos demuestran. Eso último es, literalmente, el trabajo de un auditor.

DEMOSTRACIÓN • 5 MINUTOS

Un resumen no se parece a su entrada

Escriba en el primer recuadro y cambie **una sola letra** en el segundo. Los dos resúmenes no se parecen en nada: esa es la propiedad que hace útil a una función de resumen, y también la que hace inútil compararlas «por parecido».

ENTRADA A

Transferencia por 100000 aprobada

ENTRADA B

Transferencia por 900000 aprobada

FUNCIÓN

SHA-256 ▼

coinciden 6 % de los dígitos, lo mismo que dos resúmenes al azar

Panel interactivo • ábralo en el navegador para ejecutarlo

Por qué esto no protege una contraseña

Que el resumen cambie por completo con un solo bit no protege una contraseña. Quien quiera averiguarla no intenta parecerse: **reproduce el cálculo** con una candidata y compara. La única defensa real es que cada intento cueste tiempo, y eso no lo da la función de resumen: lo da el factor de trabajo de una función de derivación, que es el ejercicio 3.

La segunda defensa es que el resultado de un intento no sirva para dos cuentas. Eso lo da **una sal distinta por usuario**. Una sal constante para toda la base —como la que declara la documentación de Coopaburrá— no aporta eso: solo obliga a rehacer el cálculo una vez más, con esa sal.

EJERCICIO 1 • 10 MINUTOS

Identificar la función sin ver el código

A partir de la longitud del resumen, determinen qué función lo produjo. Justifiquen con el número de bits, no con la apariencia.

ANALIZADOR DE RESÚMENES

5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8

Pegue cualquiera de los resúmenes de la evidencia B

Panel interactivo • ábralo en el navegador para ejecutarlo

La evidencia B, tal como está en el expediente

id	usuario	hash
1	usuario_a	5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8
2	usuario_b	7c4a8d09ca3762af61e59520943dc26494f8941b
3	usuario_c	5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8

sal declarada por la fábrica de software: constante "c00pab2019" para todos los registros

Dos observaciones saltan de inmediato, y las dos dicen algo grave. La primera es la longitud. La segunda es que dos usuarios distintos tienen exactamente el mismo resumen. Escriban qué significa cada una **antes** de pasar al ejercicio 2.

EJERCICIO 2 • 20 MINUTOS

Reproducir el cálculo

Las contraseñas del ejemplo son las dos más genéricas que existen, las de cualquier manual de seguridad. El objetivo no es adivinarlas: es **comprobar en cuál de tres condiciones** el resumen de la evidencia se reproduce, porque eso revela si la sal declarada se aplicó o solo está documentada.

REPRODUCIR EL CÁLCULO CON CANDIDATAS

CANDIDATAS, SEPARADAS POR ESPACIOS. YA VIENEN LAS DOS GENÉRICAS; AGREGUEN LAS SUYAS.

```
password 123456
```

—

Panel interactivo · ábralo en el navegador para ejecutarlo

Condición 1

El resumen de la candidata sola, sin ninguna sal.

Condición 2

El resumen de la candidata con la sal declarada **detrás**.

Condición 3

El resumen de la candidata con la sal declarada **delante**.

Si la sal se aplicara, coincidiría la condición 2 o la 3. Que coincida la 1 demuestra que la sal declarada no se está usando: es un hallazgo con nombre propio.

LO MISMO DESDE LA LÍNEA DE COMANDOS, PARA VERIFICAR A MANO

```
echo -n "password" | openssl dgst -sha1
echo -n "passwordc00pab2019" | openssl dgst -sha1
echo -n "c00pab2019password" | openssl dgst -sha1
```

Y EN PYTHON, QUE ES COMO VA EN EL INFORME

```
import hashlib

objetivo = "5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8" # usuario_a y usuario_c
candidata = "password"
sal = "c00pab2019"

sin_sal = hashlib.sha1(candidata.encode()).hexdigest()
con_sal = hashlib.sha1((candidata + sal).encode()).hexdigest()
sal_ante = hashlib.sha1((sal + candidata).encode()).hexdigest()

for nombre, valor in [("sin sal", sin_sal), ("sal detras", con_sal), ("sal delante", sal_ante)]:
    if valor == objetivo:
        print("coincide con:", nombre)
```

QUÉ SE ENTREGA DE ESTE EJERCICIO

- En cuál de las tres condiciones coincidió cada resumen.
- Qué les dijo el hecho de que dos usuarios compartieran resumen, antes de calcular nada.
- **La discrepancia.** La documentación de la fábrica de software afirma una cosa; los datos demuestran otra. Escríbanla como la escribiría un auditor: qué se afirma, qué se comprueba, y qué habría que revisar para confirmarlo en la base real y no solo en la muestra.

Cómo se escribe una discrepancia sin acusar a nadie

Un hallazgo de auditoría no dice «mintieron». Dice qué afirma la fuente, qué muestra la evidencia y qué falta por verificar. Por ejemplo: «*La documentación del proveedor declara una sal constante aplicada a todos los registros. Sobre la muestra entregada, los resúmenes se reproducen sin sal. No es posible determinar con esta muestra si la sal se omite en toda la base o solo en estos registros; se requiere revisar el código de registro y de cambio de contraseña.*»

Esa última frase —lo que falta por verificar— es la que separa un informe utilizable de una acusación.

EJERCICIO 3 • 15 MINUTOS

Medir la diferencia

Calculen cuánto tarda una función de derivación moderna frente a un resumen simple para el mismo intento, y extrapolen: ¿cuánto costaría revisar las 142.000 cuentas en cada esquema?

CALCULADORA DEL COSTO

TAMAÑO DEL RECORRIDO

10 millones de candidatas ▼

ITERACIONES DE LA DERIVACIÓN

600.000 ▼

Las velocidades son las de este navegador, que es de los peores instrumentos posibles para esta tarea. La conclusión no cambia con un instrumento mejor; cambia de escala.

Panel interactivo • ábralo en el navegador para ejecutarlo

Las dos cosas que está midiendo esta calculadora, y que conviene no confundir

El factor de trabajo decide cuánto cuesta cada intento. Un resumen simple está diseñado para ser rápido —es lo que se le pide a un resumen— y por eso es pésimo para guardar contraseñas. Una función de derivación está diseñada para ser lenta a propósito, y esa lentitud es la defensa.

La sal única por usuario decide cuántas veces hay que pagar ese costo. Sin sal, o con una sal constante, el recorrido se hace **una sola vez** y sirve para las 142.000 cuentas a la vez. Con una sal distinta por usuario, hay que repetir el recorrido entero **una vez por cuenta**. Ese factor de 142.000 no lo aporta el algoritmo: lo aporta el diseño.

```
import hashlib, time

t = time.perf_counter()
hashlib.scrypt(b"candidate", salt=b"sal-única-16-bytes", n=2**14, r=8, p=1)
print(round(time.perf_counter() - t, 3), "segundos por intento")
```

REPASO • 5 MINUTOS

¿Qué falló en cada caso?

Seis situaciones. Elijan la causa principal, la que habría evitado el problema.

1. La tabla guarda el resumen SHA-1 de la contraseña, sin ningún factor de trabajo.

2. Dos usuarios distintos tienen exactamente el mismo resumen en la tabla.

3. La documentación declara una sal constante, pero los resúmenes se reproducen sin ella.

4. La política del portal permite contraseñas de seis caracteres y no obliga a cambiarlas.

5. Alguien pega el resumen en una página que promete revelarlo, y funciona al instante.

6. El área quiere cifrar las contraseñas para poder recuperarlas y enviárselas al usuario que las olvidó.

CIERRE

Qué se entrega y cómo se califica

Una página por equipo al final del bloque. Se evalúa el análisis, no el resultado.

- ☐ Qué función produjo los resúmenes y con qué argumento lo sostienen.
- ☐ Qué significaba, antes de calcular nada, que dos usuarios compartieran resumen.
- ☐ La condición en que se reprodujo cada resumen.
- ☐ La discrepancia entre la documentación y los datos, redactada como hallazgo.
- ☐ La tabla de costos del ejercicio 3, con las dos filas: sin sal y con sal única por usuario.

- ☐ Una frase: de las tres cosas que están mal en el hallazgo H1 —la función, la sal y la política de contraseñas—, ¿cuál arreglarían primero y por qué?

Regla de trabajo del módulo. No peguen la evidencia B ni sus resultados en sitios en línea de terceros. Existen páginas que ofrecen «revelar» un resumen pegándolo en una caja: lo que hacen es quedarse con lo que usted les pegó.